

Anil Seth



Emailing Information, Secure and Convenient

GnuPG is the OpenPGP solution for securing financial and other information in an online world prone to compromised email accounts.

I like email and find it immensely useful. I suppose that reveals my age! However, I do believe that email is an excellent medium for receiving personalised information. I expect it to be reliable and, hence, someone else's information being sent to you or me is just unacceptable.

You may have also received emails asking you to contact support@company.com in case the email is not meant for you. At times if you inform them, you may get a polite automated response and, often, there is silence as if your email has gone to the spam folder.

Verifying emails

It seems very strange to receive emails related to financial data like investments and loans, which are meant for someone else. Given the significance of emails, verifying an email before activating it should be the default condition. Financial institutions may use their 'one time password' infrastructure to do so. It is also easy to find examples of open source code to verify email before activation for many programming languages. There is just no reason not to guard against the customer making a mistake or a data entry error.

Acknowledgments are a must

Most of the readers of this magazine are probably aware that Gmail regards `lname.fname@gmail.com` as the same as `lnamefname@gmail.com`. It seems likely that some organisations treat them as different email IDs. That was my interpretation when my emails stopped after I complained about receiving someone else's statements!

I am hoping that I will stop receiving the wrong statements now that I sent the complaint using the synonymous email ID. However, I will know about this only after a month as there hasn't been a single acknowledgement email.

Would you like to deal with such an organisation if you could avoid it? It seems a pity since this is a commonly used action and it is easy to find sample code for sending an email acknowledgement in various languages.

Encryption—protection from deliberate attack

You will find that most of the financial institutions are using passwords based on your PAN, name, address or account number. None of these are particularly confidential. This protection will guard against accidental exposure, e.g., the statements going to the wrong email ID. However, if your accounts were compromised, these documents will not be safe. Even brute force attacks on documents with such passwords are not difficult.

If the financial institutions were serious about security concerns, they should have offered you the option of using GPG private/public key encryption. You would upload your public key to their site or, better still, it could be a part of the KYC (know your customer) infrastructure. Each document they send you would be encrypted by your public key. Unless you lost your private key, the chances of your documents being compromised even if your email account was compromised, would be remote.

It is a nuisance to keep track of which type of password is used by which organisation, every time you receive a document. And if I want to keep a decrypted version of the PDF document on my desktop, the easiest way for me is to print the password protected PDF document to a PDF file!

On the other hand, it is not difficult to use GPG encryption on KDE and GNOME desktops now. You can experiment with them. Here is a sample KDE session.

Run `kgpg`.

Create the configuration file and a new key pair. Remember the pass phrase you use; it is easy, e.g., "Even I can remember my pass-phrase."

In `kgpg` configuration, disable *Ascii Armoured Encryption* as the default (for convenience only).

Export the public key and send it to a friend.

Receive the friend's public key and import it in `kgpg`, and sign it to trust it.